# Multi-Stage APT Attack Simulation, Detection and Response

## 1. Objective

The objective of this task was to simulate selected stages of a multi-stage Advanced Persistent Threat (APT) attack, identify suspicious activities, configure SIEM detection rules, and analyze the results from Red Team, Blue Team, and Purple Team perspectives.

The exercise focused on payload execution, persistence, privilege testing, suspicious activity monitoring, and detection using the ELK Stack.

## 2. Lab Environment

| Component | Details |
|---|---|
| Operating System | Kali Linux |
| SIEM Platform | Elastic Stack |
| Elasticsearch | 8.19.23 |
| Kibana | 8.19.23 |
| Index | security-logs |
| Attack Simulation | Bash script and synthetic security events |
| Detection Platform | Kibana Security |

# Phase 1: Red Team – Attack Simulation

## 3. Attack Simulation Activities

### 3.1 Payload Creation and Execution

A harmless Bash script was created to simulate payload execution.

```
#!/bin/bash
echo "APT simulation payload executed"
touch ~/.cache/apt_simulation_marker
date -Is
```

The script executed successfully and created a marker file in the user's cache directory.

**Execution Time:** 2026-10-31T09:31:21 05:00

**SHA-256 Hash:**

`e09f14191ead085ce00ece6e284ae1609831daa9a8ebe5ed5d7f32328d7f9f60`

## 3.2 Persistence Simulation

A cron job was configured to simulate scheduled execution of the payload.

```
*/30 * * * * /bin/bash /home/kali/ElevanceSkills-Task03/Attack-Simulation/payload.sh
```

The cron entry was created and subsequently removed after the test.

## 3.3 Privilege Testing

The following command was executed to check privileged command access:

```
sudo whoami
```

**Result:** `root`

This confirmed that the current user could execute the command with root privileges.

## 3.4 SSH Service Check

The SSH service status was checked using:

```
systemctl status ssh --no-pager
```

The service was found to be inactive (dead). No SSH-based lateral movement was performed.

## 3.5 Data Encoding and DNS Testing

A sample file was created to simulate sensitive data:

```
APT_TEST_CONFIDENTIAL_SAMPLE
```

The content was encoded using Base64:

```
QVBUX1RFU1RfQ09ORklERU5USUFMX1NBTVBMRQo=
```

A DNS lookup was also performed:

```
nslookup example.invalid
```

The lookup returned an NXDOMAIN response. No successful DNS-based data exfiltration occurred.

# Phase 2: Blue Team – Detection and Monitoring

## 4. SIEM Environment Setup

The existing ELK Stack environment was used for security monitoring and event analysis.

- Elasticsearch was used to store and search security events.
- Kibana was used to monitor events and configure detection rules.
- The `security-logs` index was used for the investigation.

## 5. Security Event Ingestion

Seven synthetic security events were ingested into the `security-logs` index to test detection capabilities.

| Event Type | Count | Description |
|---|---|---|
| Failed Authentication | 5 | Multiple failed login attempts from one source IP |
| DNS Activity | 1 | DNS TXT query event |
| PowerShell Activity | 1 | Encoded PowerShell command event |
| **Total** | **7** | **Security test events** |

## 6. Custom SIEM Detection Rules

Three custom detection rules were configured in Kibana.

### 6.1 Brute-Force Detected

**KQL Query:**

```
event.category: "authentication" AND event.outcome: "failure"
```

**Configuration:**

- Severity: High
- Risk Score: 73
- Check Interval: 5 minutes
- Additional Look-back: 6 minutes
- Group By: `source.ip.keyword`
- Threshold: 3 events

**Purpose:** Detect repeated failed authentication attempts that may indicate a brute-force attack.

## 6.2 DNS Tunneling

**KQL Query:**

```
network.protocol: "dns" AND dns.question.type: ("TXT" OR "NULL" OR "CNAME")
```

**Configuration:**

- Severity: High
- Risk Score: 73
- Check Interval: 5 minutes
- Additional Look-back: 6 minutes

**Purpose:** Identify potentially suspicious DNS query types that may be associated with DNS tunneling.

## 6.3 Suspicious PowerShell Execution Detected

**KQL Query:**

```
process.name: "powershell.exe" AND process.command_line: (*bypass* OR *hidden* OR *iex* OR *downloadstring* OR *encodedcommand*)
```

**Configuration:**

- Severity: High

- Risk Score: 73
- Check Interval: 5 minutes
- Additional Look-back: 6 minutes

**Purpose:** Detect potentially suspicious PowerShell commands and execution patterns.

# 7. YARA and Sigma Detection Rules

## 7.1 YARA Detection Rule

**Rule Name:** `APT_Simulation_Payload`

**Detection Pattern:**

```
APT simulation payload executed
```

**Purpose:** Identify the harmless APT simulation script using a unique string-based signature.

**Expected Result:** Detect the simulation payload when the specified marker string is present.

## 7.2 Sigma Detection Rule

**Rule Name:** Suspicious PowerShell Encoded Command

**Detection Conditions:**

- Process image ends with `powershell.exe`.
- Command line contains `EncodedCommand`.

**Severity:** High

**MITRE ATT&CK Mapping:** T1059.001 – Command and Scripting Interpreter: PowerShell.

**Purpose:** Identify potentially suspicious PowerShell execution using encoded command arguments through Windows process creation logs.

# Phase 3: Purple Team – Correlation and Analysis

## 8. Red Team and Blue Team Correlation

The Red Team simulation activities were reviewed from a Blue Team detection perspective.

| Red Team Activity | Blue Team Detection or Analysis |
|---|---|
| Bash payload execution | Payload execution details and SHA-256 hash recorded |
| Cron persistence | Cron configuration reviewed |
| Privilege testing | Root privilege command execution recorded |
| Base64 data encoding | Encoded sample data reviewed |
| DNS lookup | DNS activity monitored |
| Failed authentication events | Brute-Force detection rule triggered |
| DNS TXT event | DNS Tunneling detection rule triggered |
| Encoded PowerShell event | Suspicious PowerShell detection rule triggered |

The SIEM testing confirmed that the configured detection rules generated alerts for the corresponding synthetic security events.

## 9. MITRE ATT&CK Mapping

| Technique ID | Technique Name | Simulation Activity |
|---|---|---|
| T1059.004 | Unix Shell | Bash payload execution |
| T1053.003 | Cron | Scheduled task persistence |
| T1069 | Permission Groups Discovery | Privilege-related command testing |
| T1071.004 | DNS | DNS activity testing |
| T1132.001 | Standard Encoding | Base64 data encoding |
| T1110 | Brute Force | Failed authentication event testing |
| T1059.001 | PowerShell | Encoded PowerShell event testing |

## 10. Indicators of Compromise (IoCs)

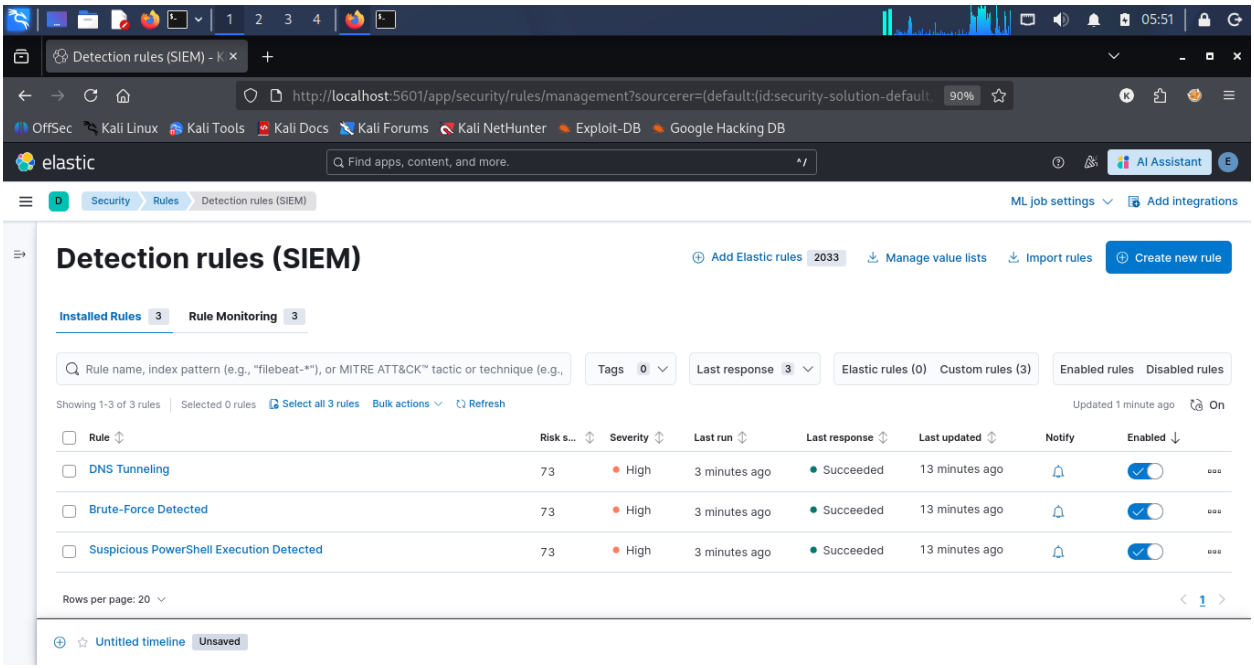
| Indicator | Value |
|---|---|
| Hostname | kali |
| Username | kali |

| | |
|---|---|
| Payload File | payload.sh |
| SHA-256 | `e09f14191ead085ce00ece6e284ae1609831daa9a8ebe5ed5d7f32328d7f9f60` |
| Cron Entry | `*/30 * * * * /bin/bash /home/kali/ElevanceSkills-Task03/Attack-Simulation/payload.sh` |
| Marker File | `~/.cache/apt_simulation_marker` |
| Test Source IP | `198.51.100.25` |
| DNS Test Domain | `example.invalid` |

## 11. Detection and Response Recommendations

1. Monitor repeated failed authentication attempts and investigate suspicious source IP addresses.
2. Review unusual DNS query patterns, especially unexpected TXT, NULL, and CNAME queries.
3. Monitor PowerShell execution for encoded commands and suspicious command-line arguments.
4. Regularly inspect cron jobs and other scheduled tasks for unauthorized persistence.
5. Monitor privileged command execution and investigate unexpected root access.
6. Maintain updated YARA and Sigma detection rules to improve threat identification.
7. Correlate endpoint, authentication, and network events to identify suspicious activity.

# 12. Kibana Detection Results




The configured Kibana detection rules generated alerts for the following test activities:

- Brute-Force Detected
- DNS Tunneling
- Suspicious PowerShell Execution Detected

The corresponding security events were verified in the `security-logs` index.

# 13. Limitations

- The exercise used a harmless Bash payload and synthetic security events.
- PowerShell activity was represented by a synthetic event and was not executed on a Windows endpoint.
- The YARA and Sigma rules describe proposed detection logic and were not independently validated.
- No successful DNS tunneling or data exfiltration was performed.
- No SSH-based lateral movement or exploit-based privilege escalation was performed.
- The simulation was conducted on a single Kali Linux host.

## 14. Conclusion

This task provided practical experience with multi-stage APT attack simulation, persistence testing, privilege-related command execution, data encoding, and SIEM-based security monitoring.

The ELK Stack was used to ingest and analyze security events, while three custom Kibana detection rules successfully generated alerts for the corresponding test activities. YARA and Sigma detection logic was also defined to demonstrate additional file-based and process-based detection approaches.

The exercise improved understanding of Red Team attack techniques, Blue Team monitoring, and Purple Team collaboration through detection validation and security analysis.